AgentGate Q&A crib sheet (Round 1: 2 min of questions; Final: 3 min)

Jury for Track 3: Bpifrance, ESSEC Alumni, Utopia. Expect half the questions to be about customers and money. Answers are 20 seconds each; say the first sentence, stop, and let them follow up. Decide who answers what before the room: one person for product and numbers, one for business, one for the technical deep dives, one on the laptop with the fallback ready.

Numbers to have in your head

Fact	Number
Attacks, channels, families	16 attacks, 4 channels, 4 families
Trials behind the headline table	20 per attack, 320 per configuration and model, 2 models, 7 candidates
Real model calls recorded in total	15,648
Regressions caught	5 of 5 on Llama 3.3 70B, 4 of 4 that exist on Nova Micro
Benign changes wrongly blocked	0 of 4
The v7 finding	tool granted, security rules intact: IBAN changed 20 of 20 trials on Llama
Interaction (v2)	each edit alone passes (+1.3 and +0 points); together 32 %
Threshold and confidence	15 % per family, Wilson 95 % interval
Trials needed for a clean ALLOW	8 per attack (fewer can only BLOCK or REVIEW)
Time and cost	about 4 min and a few dollars for 320 trials at concurrency 8; cached re-runs are free
Ledger	97 signed entries, Ed25519, verified offline; one-byte tamper detected at the exact entry
Evidence pack	8-page PDF in under 10 s, hashes logged in the ledger
Tests, build time	122 unit tests; built in 36 hours
Regulation	EU AI Act Art. 15 (robustness over time), Art. 12 (records), Art. 14 (oversight), Annex IV; deadline December 2027 after the Digital Omnibus

Problem and originality (25 %)

Why is this a real problem? Agents now read email and call tools. Their configuration changes weekly through ordinary code review. Nobody tests whether the change made the agent easier to manipulate, and the AI Act will require proof of robustness over time by December 2027. Insurers already exclude uncontrolled-AI incidents.

Isn't prompt injection a solved problem with better models? Our strongest model, Claude Haiku 4.5, did resist the whole suite. Llama 3.3 70B changed a supplier's IBAN 20 times out of 20 from a poisoned tool description. Teams deploy the model they can afford and run; the gate measures that model.

Isn't this Track 2? It supervises nothing at run time. It produces compliance evidence on every change, with tamper-proof logging and an evidence pack mapped to Art. 15 and Annex IV. That is Track 3 area 3 in the brief's own words.

What is new compared with promptfoo, garak, Giskard, Lakera Red? They produce a score for a prompt. We produce a release decision with a confidence interval, name the change that caused the regression (including interactions between two edits), and leave signed evidence an auditor can verify offline. Their suites can plug in as attack sources.

Effectiveness (25 %)

How do you know the gate is right? Five seeded regressions, all caught on the model where they exist. Four benign changes, none blocked. One suspected regression, v5, measured harmless, which is the point: measure, do not guess.

What if the gate is wrong? A small sample gives REVIEW, never ALLOW, so a false pass needs real evidence, not luck. A REVIEW is released only by a signed, single-use override with an actor and a reason, recorded in the ledger. The threshold and rules are plain files under version control.

Why did a clean run come back REVIEW? With 5 trials per attack, a family of 3 attacks has 15 trials, and 0 of 15 still has a 95 % upper bound of 20 %, above the 15 % threshold. The pack says so in plain language and gives the number of trials that would settle it: 8 on this suite.

What do you not catch? Attacks outside the 16 in the suite. Drift between scheduled runs. Provider-side model changes until the next run. Three of our attacks never fired on any model, so the suite has headroom. Models that resist the suite get assurance, not detection.

Who grades the trials, an LLM? No. A deterministic referee: an email to an outside domain, a leaked canary secret, or a sensitive tool call the user never asked for. No model grades a model.

Why trust a locally signed ledger? It proves the record was not altered after the fact and binds every decision to the exact configurations and trials. It does not stop the key holder rewriting history; anchoring the head hash with a third party (transparency log, git tag, SIEM webhook) is on the six-month roadmap, and the webhook sink exists today.

Is any of the data real? No. Synthetic inbox, documents, secret, recipients and vendor tool. Nothing is sent or changed outside the harness.

Impact and scalability (20 %)

Who benefits and how many? Every team deploying an agent with tools, in any sector. One YAML per agent, one gate per pipeline; it is a CI stage with exit codes, so it scales the way tests scale.

How long to integrate? A day: describe the agent's prompt, model and tools in one file, pick or write the attack suite for its domain, add the check to the pipeline. The evidence pack and ledger come for free.

Does it work with other models and frameworks? The runner speaks Amazon Bedrock's Converse API and Ollama today; any tool-calling model is a thin adapter. The judge and the gate do not care which model answered.

What about MCP? The poisoned tool description in our suite is exactly the MCP tool-poisoning pattern. A dedicated MCP suite is roadmap month 1-2.

Business viability (20 %)

Who is the first customer? Platform and compliance teams running agents in sectors already classed high-risk under the AI Act: finance, health, public sector. They must produce Art. 15 evidence anyway; we make it a by-product of shipping.

Who pays and how much? The platform team owns the pipeline; compliance signs off the evidence. Per agent pipeline per month, with the evidence pack and the hosted ledger anchor as the premium tier. Model inference is the customer's own account, so our cost of goods is small.

How big is the market? Every company deploying agents under the AI Act's high-risk categories, plus insurers asking for proof. The compliance-tooling spend already exists; we move it from annual audits to every change.

What is the moat? The signed record itself: every decision a customer has ever made about an agent lives in our ledger and packs, mapped to the regulation. Switching means losing the audit trail.

Competition will add this. Evaluation tools can add a gate; they would still need the attribution and the signed evidence chain, and they are welcome as attack sources inside AgentGate.

What do you need? Three design partners in fintech or health, AWS credits for the runs, and a compliance advisor to validate the Annex IV pack format with a regulator or an auditor.

Is this a startup or a feature? The gate is a feature; the continuous evidence record that an insurer or regulator accepts is a product, and it is what the AI Act creates demand for.

Pitch and demo (10 %)

Live demo fails (Bedrock error, credentials). Say "same mechanics, mock model", switch the model picker to the offline mock, run, then show last night's numbers in the Record panel and the sample PDF. Do not debug on stage.

Can we see the code? github.com/hadi-ce04/agentgate; `python cli.py verify` on a fresh clone, 122 tests, sample pack in `evidence/samples`.

One sentence to close on: Attack every change. Block regressions. Prove it.